REPORTE TÉCNICO DE INCIDENTE · TLP:RED

Acceso no autorizado a facturas de clientes en el servicio de consulta de facturas

Enumeración automatizada de facturas a través de GET /invoices/search entre el 1 de octubre y el 31 de diciembre de 2020

1. Identificación del incidente

Referencia del incidente	IR-2021-001	**Fecha del reporte**	14 de octubre de 2026
Líder técnico del caso	Yeyson Javier Cañón Forero, líder técnico de respuesta a incidentes	**Clasificación**	TLP:RED
Categoría (taxonomía de referencia ENISA / eCSIRT.net)	Information Content Security: Unauthorised access to information. Fases relacionadas: Information Gathering (Scanning) e Intrusions (Application compromise, pendiente de confirmar)	**Referencia OWASP**	API1:2023 Broken Object Level Authorization; Top 10 A01:2021 Broken Access Control; OAT-011 Scraping; CWE-639; Insecure Direct Object Reference OWASP.
Activo afectado	Servicio web mercadolibre.com para consulta de facturas, GET /invoices/search, expuesto a Internet y compartido por los sitios de Argentina, Brasil, Colombia y México	**Información comprometida**	Facturas de clientes, que según el escenario contienen datos personales. El registro no incluye el contenido de las respuestas; los campos expuestos (por lo general nombre, identificación tributaria, dirección, productos y montos) deben confirmarse con el dueño del servicio
Inicio de la actividad maliciosa	1-oct-2020 00:00 (primer registro disponible; pudo ser anterior)	**Primer acceso exitoso**	1-nov-2020 00:04
Última actividad observada	31-dic-2020 23:57 (fin del registro disponible)	**Fecha de detección**	12-ene-2021, alerta del WAF y monitoreo interno
Tiempo de detección (TTD)	103 días desde la primera actividad; 72 días desde el primer acceso exitoso	**Tiempos de respuesta**	TTR 39 minutos (0,65 h) · TTC 1 hora 54 minutos (1,9 h) desde la detección
Alcance	Campaña 1 (atacante): 5 direcciones IP, 4 credenciales, 61.961 peticiones. Campaña 2 (por validar, probable actividad interna): 5 IP de una misma red, 3 credenciales posiblemente de pruebas	**Exposición potencial**	Entre 10.181 y 27.746 facturas, según el esquema de numeración (sección 6)
Severidad	Crítica	**Estado**	Contenido. Corroboración del impacto y erradicación en curso. Riesgo residual: medio

El 12 de enero de 2021 una alerta del firewall de aplicaciones web (WAF), sumada al monitoreo interno, señaló un volumen anómalo de consultas al servicio de facturas. El análisis de los registros de acceso de los tres meses anteriores mostró que cuatro credenciales válidas del portal, usadas desde cinco direcciones IP, consultaron de forma automatizada y sostenida miles de facturas por número consecutivo, con respuestas exitosas del servidor. El comportamiento es consistente con la explotación de una falla de autorización a nivel de objeto: el servicio verifica que la credencial sea válida, pero no que la factura consultada pertenezca a su titular.

La actividad se desarrolló en tres fases: un mes de pruebas sin éxito, un mes de extracción moderada y un mes de extracción masiva en el que el atacante consultó facturas que ningún cliente había solicitado. Al cierre del registro disponible la actividad continuaba. Las medidas de contención se aplicaron dentro de las dos horas siguientes a la detección y la corrección del servicio está en curso.

Grado de certeza de las conclusiones

El registro de acceso muestra qué se solicitó y qué respondió el servidor, pero no contiene el titular de cada factura, la identidad autenticada ni la decisión de autorización de la aplicación. Con esta fuente, el acceso indebido se sostiene como una ***hipótesis de alta confianza*** *respaldada por seis indicios independientes, y las cifras de facturas y titulares corresponden a exposición potencial, es decir, a un límite superior. La confirmación del acceso indebido y del número exacto de afectados depende del cruce con la base de titulares del servicio, solicitado al dueño del servicio y en curso.*

A lo largo del reporte se distinguen tres grados de afirmación. Un **hecho** es un dato verificable directamente en el registro y reproducible con una consulta. Una **evidencia** es un patrón observado que soporta una inferencia. Una **hipótesis** es una interpretación que requiere otra fuente para confirmarse. Los términos técnicos y abreviaturas se explican en el glosario al final del documento.

2. Metodología de investigación

La investigación siguió el ciclo de gestión de incidentes de NIST SP 800-61. La regla de trabajo fue preservar antes de analizar, trabajar siempre sobre copias derivadas y documentar cada paso para que cualquier conclusión pueda reproducirse.

2.1 Fuentes analizadas

La fuente principal es el registro de acceso HTTP del servicio (three_months.csv, 1,18 GB, 4.478.619 registros) entre el 1 de octubre y el 31 de diciembre de 2020. Cada registro contiene fecha y hora, código de respuesta, host, URI con sus parámetros (invoice_id, site_id y authtoken), método, referer, agente de usuario (user agent) e IP de origen. Todo el tráfico corresponde a un único host y al método GET. Como fuentes complementarias se consultaron servicios de inteligencia de amenazas (VirusTotal, AlienVault OTX y la instancia MISP) para las direcciones IP públicas involucradas.

2.2 Alcance y preservación de la evidencia

Se analizó la totalidad del tráfico del endpoint en el periodo disponible: 5.726 direcciones IP y 35 credenciales. Antes de cualquier procesamiento se calculó la huella SHA-256 del archivo original (128f5d7d57ce8ee30d2d22df2c6f43552963b55c44e3e560f6db8032aca9841a), se dejó el original en solo lectura y se registró la recepción en una cadena de custodia encadenada por hash, en la que la alteración de cualquier evento invalida los siguientes. El análisis se hizo sobre una copia derivada y cada resultado quedó en un manifiesto con su propia huella. Las credenciales se tratan en el reporte por una huella irreversible y una pista parcial, nunca por su valor completo.

2.3 Técnicas y herramientas

El tráfico se agregó por dirección IP y por credencial, porque el tráfico legítimo está muy disperso y una sola dimensión ocultaría un ataque distribuido. Para cada actor se midieron el volumen diario, el número de facturas distintas consultadas, la cobertura de rangos consecutivos de facturas y la proporción de herramientas automatizadas. La anomalía se estimó con estadística robusta (desviación respecto de la mediana, que el propio atacante no puede distorsionar) y con un modelo de detección de anomalías (Isolation Forest) usado como señal complementaria. Los actores sospechosos se agruparon en campañas cuando compartían credenciales, se segmentaron las fases por cambios sostenidos de volumen y se comparó cada factura consultada contra la línea base del tráfico legítimo.

El procesamiento se realizó con un pipeline forense propio en Python (Polars), con cadena de custodia integrada. Las cifras de este reporte se recalcularon de forma independiente con consultas SQL en DuckDB sobre el archivo original. Las técnicas del atacante se mapearon contra MITRE ATT&CK Enterprise. Antes de aplicarlo al caso, el método de detección se probó contra tráfico etiquetado con escenarios difíciles (redes corporativas con muchos usuarios detrás de una IP, integraciones legítimas automatizadas y cinco estilos de ataque, incluidos atacantes lentos y con rotación de IP); en esa prueba ninguna actividad legítima quedó clasificada como campaña de alta confianza.

EJERCICIO TÉCNICO · INFORMACIÓN FICTICIA

2.4 Limitaciones

- El registro no contiene el titular de cada factura ni la decisión de autorización de la aplicación. Es la razón por la que el acceso indebido se presenta como hipótesis de alta confianza y no como hecho demostrado.
- No se conoce si el número de factura es único en toda la plataforma o si cada sitio lleva una numeración independiente. Esto cambia el conteo de facturas expuestas (sección 6).
- La primera petición maliciosa coincide con el primer registro disponible: la actividad pudo empezar antes del 1 de octubre de 2020.
- El formato de fecha del registro no es estándar (año-día-mes), no incluye segundos ni zona horaria, y no se registran el usuario, la sesión ni el tamaño de la respuesta. Leído con el formato habitual, el 61 % de los registros quedaba sin fecha; el formato se identificó y verificó antes del análisis.
- La reputación obtenida de fuentes de inteligencia corresponde al momento de la consulta y no a la fecha de los hechos; se usa como contexto y no como prueba de atribución.

3. Cronología del incidente

Para efectos de este reporte, una **campaña** es un conjunto de direcciones IP y credenciales que actuaron de forma coordinada, identificado al agrupar las IP que usaron las mismas credenciales. La **campaña 1** corresponde a la actividad atribuida al atacante. La **campaña 2** corresponde a una actividad con credenciales posiblemente de prueba que, por sus características, parece ser interna y se encuentra en validación.

Fecha y hora	Evento	Grado	Hallazgo asociado
1-oct-2020 00:00	Primera petición de la campaña 1 desde la dirección IP 216.21.168.27 con la herramienta crawler4j; el servidor responde con error 406	Hecho	Inicio del reconocimiento. Coincide con el primer registro disponible
1-oct-2020 00:23	Aparece la herramienta Scrapy 2.3.0. Durante octubre la campaña envía exactamente 48 peticiones diarias, todas rechazadas (códigos 400, 406 y 408)	Hecho	Los errores 406 y 408 solo aparecen en esta campaña: el atacante calibra la herramienta
1-nov-2020 00:04	Primera respuesta exitosa: factura 118.822.059 entregada a la IP 24.163.83.34	Hecho	Inicio de la exposición
1 al 30-nov-2020	504 peticiones diarias exactas con 40 % de éxito, dentro del rango de facturas que consulta el tráfico legítimo	Hecho	Fase de explotación
1-dic-2020 00:02	Aparece la herramienta wget y la primera consulta de una factura fuera del rango usado por los clientes	Hecho	El atacante amplía el espacio de búsqueda
1 al 31-dic-2020	1.463 peticiones diarias exactas con 94 % de éxito; 5.232 facturas que ningún otro actor consultó	Hecho	Fase de extracción masiva
1-dic-2020 08:09	Inicia la campaña 2: herramienta Postman con tres credenciales posiblemente de prueba: TEST-ID-developuser TEST-ID-websectest TEST-ID-websecuser Desde 181.88.192.0/24, solo entre las 08:00 y las 18:59, sin salir del rango legítimo	Hecho	Perfil compatible con pruebas internas
31-dic-2020 23:57	Última petición registrada de la campaña 1, que coincide con el fin del registro	Hecho	No hay evidencia de que la actividad haya cesado
12-ene-2021	Detección por alerta del WAF y monitoreo interno; apertura del incidente IR-2021-001	Hecho	TTD de 103 días
Detección + 39 min	Evidencia preservada, alcance caracterizado y plan de respuesta aprobado	Hecho	TTR de 0,65 horas
Detección + 1 h 54 min	Contención inmediata aplicada: límite de peticiones, regla de bloqueo en el WAF, bloqueo de IP y revocación de credenciales	Hecho	TTC de 1,9 horas

FICCIÓN

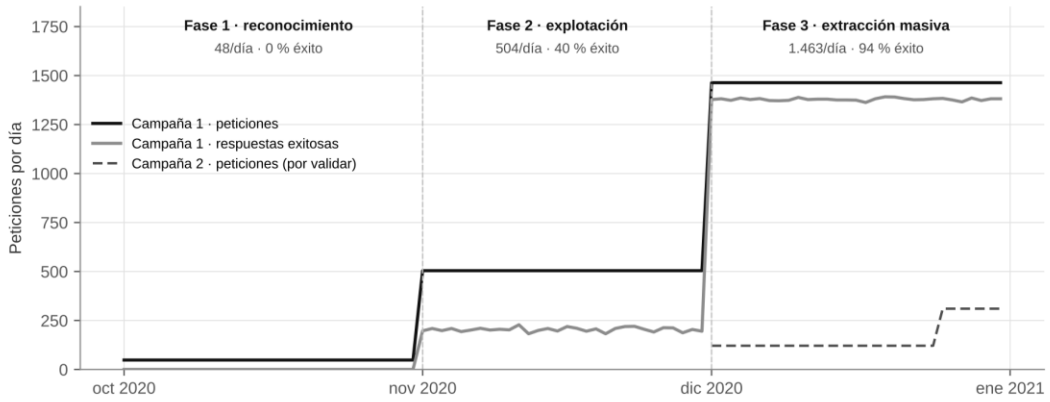


Figura 1. Peticiones diarias de las campañas 1 y 2. Los tramos planos en cada fase indican un proceso automatizado con una tasa fija.

4. Evidencia de explotación

4.1 Hallazgos y correlación de eventos

Los hallazgos se presentan con su grado de certeza. Los siete primeros son hechos o evidencias verificables en el registro; el octavo es la conclusión que se desprende de ellos y que queda sujeta a confirmación.

Hallazgo	Grado	Evidencia que lo soporta
Las cuatro credenciales de la campaña 1: ATUSER-ID-jacintobuyer ATUSER-ID-marcianobuyer ATUSER-ID-mantecoluser ATUSER-ID-mateuser Recibieron 48.827 respuestas exitosas sobre 10.181 números de factura distintos, en los cuatro sitios (27.746 combinaciones de factura y sitio)	Hecho	Conteo directo sobre el registro, verificado con consultas independientes
Todas las respuestas exitosas de la campaña 1 se dieron con una credencial válida y ninguna de sus peticiones recibió un rechazo por autenticación (401) o por autorización (403), mientras que el resto del tráfico registra 735.324 respuestas 401	Hecho	El servidor aceptó las credenciales sin restricción alguna: la falla no es de autenticación
5.232 facturas (números 118.826.001 a 118.831.340) fueron consultadas únicamente por la campaña 1	Hecho	Ningún cliente las solicitó en tres meses de tráfico legítimo
Las facturas se recorrieron por rangos consecutivos: 118.822.000 a 118.831.340 y 229.933.000 a 229.933.999, con una cobertura cercana al 66 %	Evidencia	Enumeración sistemática. El orden exacto petición a petición no es observable porque el registro tiene resolución de minuto
Las herramientas Scrapy, crawler4j y wget aparecen exclusivamente en la campaña 1, con volumen diario idéntico dentro de cada fase y actividad uniforme las 24 horas (entre 2.335 y 2.862 peticiones por franja horaria en el periodo)	Evidencia	Automatización. El tráfico legítimo usa navegadores y sigue el ciclo de día y noche
Cada una de las cuatro credenciales se usó desde las cinco direcciones IP de la campaña	Evidencia	Operación coordinada que reparte la carga entre direcciones para evitar bloqueos por volumen
Las 10.407 peticiones sin cabecera Referer de todo el registro provienen de la campaña 1	Evidencia	El tráfico legítimo debe llegar siempre desde la página del portal
El servicio entrega facturas sin verificar que pertenezcan al titular de la credencial que las solicita (falla de autorización a nivel de objeto, IDOR)	Hipótesis de alta confianza	Soportada por todos los hallazgos anteriores. Se confirma con el cruce de titulares y con una reproducción controlada (sección 8)

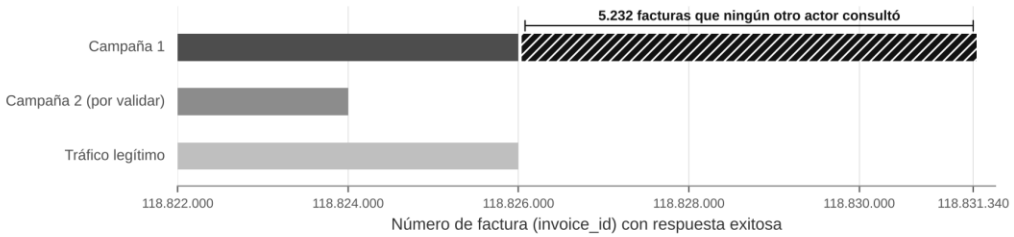


Figura 2. Rangos de facturas consultadas con éxito. En diciembre la campaña 1 sale del rango que usa el tráfico legítimo.

4.2 Actividades del atacante y técnicas (MITRE ATT&CK)

Fase	Actividad observada	Técnica
Reconocimiento	Durante un mes envía 48 peticiones diarias que el servidor rechaza, hasta ajustar el formato y los parámetros de la consulta	T1595.002 Vulnerability Scanning
Acceso inicial	Utiliza cuatro credenciales válidas del portal desde cinco direcciones IP, sin ningún intento fallido de autenticación	T1078 Valid Accounts
Explotación	Solicita facturas por número consecutivo en un servicio expuesto a Internet que responde con éxito	T1190 Exploit Public-Facing Application
Recolección	Descarga sostenida con herramientas de extracción automática a tasa fija y ampliación del rango en diciembre	T1119 Automated Collection

4.3 Artefactos identificados

No se identificaron archivos, software malicioso ni infraestructura de comando y control: el ataque opera sobre la lógica de autorización del servicio con peticiones HTTP legítimas en su forma. Los artefactos del incidente son las direcciones IP, las credenciales, los agentes de usuario de las herramientas y el patrón de enumeración descritos en la sección 5. La consulta a fuentes de inteligencia de amenazas mostró que dos de las IP de la campaña 1 (216.21.168.27 y 24.163.83.34) tienen reputación maliciosa en VirusTotal, con seis y cuatro motores de detección respectivamente, y aparecen en pulsos de AlienVault OTX; las otras tres figuran como sospechosas. Adicionalmente, varias de las direcciones del top de IP analizadas están asociadas a indicadores del troyano Emotet, conocido por el robo de credenciales. Esto abre la hipótesis de que las credenciales usadas en el ataque se hayan obtenido mediante equipos de clientes infectados con este troyano, lo que se validará con el proveedor de identidad revisando el origen y el historial de las cuentas. Se aclara que esta reputación corresponde al momento de la consulta y no a la fecha de los hechos, por lo que se usa como contexto de la investigación y no como prueba de atribución.

4.4 Campaña 2 (en validación)

Cinco direcciones de la red 181.88.192.0/24 usaron la herramienta Postman con tres credenciales identificadas como de prueba desde el 1 de diciembre, solo en horario laboral, con 100 % de respuestas exitosas sobre 2.165 facturas, todas dentro del rango que consulta el tráfico legítimo. Las mismas direcciones generan además tráfico de navegador, lo que es propio de una red corporativa. El perfil es compatible con pruebas internas de calidad o seguridad. Se decidió validarla con los equipos de AppSec y QA antes de tomar acciones sobre ella, porque bloquearla sin validación tenía un riesgo alto de afectar actividad legítima. Con independencia del resultado, el uso de credenciales de prueba en producción es una brecha de control.

5. Indicadores de compromiso

Los indicadores se entregaron al SOC en formato estructurado (JSON y CSV) para su carga en el SIEM y en el WAF, junto con la huella del archivo que los contiene. No se registran dominios ni hashes de archivos asociados al atacante, porque el incidente no involucró malware ni infraestructura propia del adversario.

Tipo	Indicador	Contexto	Uso
Dirección IP	73.130.229.200, 216.21.168.27, 74.88.210.56, 204.210.158.207, 24.163.83.34	Campaña 1, riesgo crítico. Dos con reputación maliciosa actual	Bloqueadas; búsqueda retrospectiva en otros servicios
Dirección IP	181.88.192.16, .48, .59, .87 y .115 (red 181.88.192.0/24)	Campaña 2, en validación	Monitoreo, sin bloqueo

EJEMPLO TÉCNICO · INFORMACIÓN

Tipo	Indicador	Contexto	Uso
Cuenta comprometida	Cuatro credenciales del portal con prefijo ATUSER-ID: ATUSER-ID-jacintobuyer ATUSER-ID-marcianobuyer ATUSER-ID-mantecoluser ATUSER-ID-mateuser	Usadas desde las cinco IP de la campaña 1; más de 7.100 facturas consultadas cada una	Revocadas; revisión del alta y del historial de las cuentas
Cuenta de prueba	Tres credenciales con prefijo TEST-ID: TEST-ID-developuser TEST-ID-websectest TEST-ID-websecuser	Credenciales de prueba activas en producción	Retiro en curso
Agente de usuario	Scrapy/2.3.0 (+https://scrapy.org), crawler4j, wget	Exclusivos de la campaña 1; ninguna petición legítima los usa	Regla de bloqueo en el WAF
Agente de usuario	PostmanRuntime/7.25.0	Exclusivo de la campaña 2	Alerta
Patrón de petición	GET /invoices/search con invoice_id entre 118.822.000 y 118.831.340 o entre 229.933.000 y 229.933.999, en los cuatro site_id	Enumeración por rangos consecutivos	Regla de detección por facturas distintas por credencial y día
Comportamiento	Peticiones al endpoint sin cabecera Referer; credencial usada desde más de tres IP; más de 50 facturas distintas por credencial en un día	Reglas validadas contra el histórico	Correlación en el SIEM

6. Análisis de impacto

6.1 Alcance de la exposición

La campaña 1 obtuvo respuestas exitosas para **10.181** números de factura distintos. Ese número es correcto si cada número de factura identifica un único documento en toda la plataforma. Durante el análisis se observó que el mismo número se consultó en varios sitios, y no es posible saber con el registro si la numeración es global o independiente por sitio. **Si se confirma que cada sitio lleva su propia numeración, cada combinación de número y sitio sería una factura distinta y la exposición potencial aumentaría a 27.746 facturas**: 6.899 en Argentina, 6.959 en Brasil, 6.918 en Colombia y 6.970 en México. Por esta razón el reporte expresa el alcance como un rango de 10.181 a 27.746 facturas, con igual número máximo de titulares si se asume un titular por factura. La pregunta se resuelve con el dueño del servicio dentro de la corroboración en curso.

Dimensión	Evaluación	Base y grado de certeza
Confidencialidad	Alta. Entre 10.181 y 27.746 facturas con datos personales y posiblemente financieros entregadas a credenciales de la campaña; 5.232 números nunca consultados por clientes	Exposición potencial (límite superior). Cifra confirmada pendiente del cruce de titulares
Integridad	Sin afectación observada. El servicio es de consulta y todo el tráfico usa el método GET	Hecho
Disponibilidad	Sin afectación. En su pico, la campaña representó cerca del 4 % del tráfico diario del servicio	Hecho
Operacional	Esfuerzo de respuesta, corrección y despliegue del servicio, rotación de credenciales con efecto sobre clientes y atención de consultas	Estimación
Reputacional	Exposición de datos reales de compra en cuatro mercados; riesgo de fraude dirigido y de pérdida de confianza si los datos se publican o el incidente se conoce por terceros	Estimación
Regulatorio	Posible obligación de notificar en Brasil (autoridad y titulares en tres días hábiles) y en Colombia (registro ante la SIC en quince días hábiles); México y Argentina según la evaluación jurídica	Depende de confirmar titulares y datos expuestos
Económico	Entre USD 1,6 y 4,4 millones como orden de magnitud (ver 6.2)	Estimación con supuestos explícitos

6.2 Estimación económica

Como referencia sectorial, el costo promedio de un registro de datos personales de cliente expuesto en una brecha es de USD 160 (IBM, Cost of a Data Breach 2025). Aplicado a los dos escenarios de numeración, el orden de magnitud está entre USD 1,6 millones (10.181 titulares) y USD 4,4 millones (27.746 titulares). El valor incluye respuesta, notificación, atención a clientes y pérdida de negocio, pero no sanciones. Los topes de sanción de referencia son el 2 % de la facturación en Brasil, con un máximo de R$ 50 millones por infracción (LGPD, artículo 52), y 2.000 salarios mínimos en Colombia, unos COP 3.502 millones a valores de 2026 (Ley 1581 de 2012, artículo 23). La cifra definitiva depende del número de titulares confirmados y de los campos expuestos, y debe validarla el área financiera con el área jurídica.

INFORMACIÓN

7. Causa raíz

7.1 Vulnerabilidad explotada

La causa más probable es la ausencia de verificación de propiedad del objeto en el servicio de consulta. El servicio comprueba que la credencial enviada sea válida, pero no que la factura solicitada pertenezca al titular de esa credencial ni que el sitio indicado le corresponda. Es una referencia directa insegura a objetos (IDOR), clasificada por OWASP como Broken Object Level Authorization (API1:2023) y por MITRE como CWE-639. Esta explicación es la única consistente con todos los hallazgos de la sección 4: credenciales válidas, ausencia total de rechazos, respuestas exitosas sobre facturas que ningún cliente pidió y recorrido de números consecutivos. La causa raíz se confirma con la reproducción controlada en ambiente de pruebas (dos cuentas de prueba, una solicita una factura de la otra) y con la revisión del código del endpoint, ambas en curso con el equipo de desarrollo.

7.2 Deficiencias de control

Deficiencia	Cómo contribuyó al incidente
El servicio no valida la propiedad de cada factura y acepta el sitio que envía el cliente	Permitió consultar facturas de otros clientes y de los cuatro países
Los números de factura son consecutivos y predecibles	Hizo trivial la enumeración por rangos
La credencial viaja en la URL, es de larga duración (se usó sin cambios durante tres meses) y no está ligada a una sesión ni a un dispositivo	Expone la credencial en registros, proxies y cabeceras Referer, y permitió usarla desde cinco direcciones a la vez
No existen límites de peticiones ni de objetos por credencial, y el WAF no tenía reglas de abuso de API en modo de bloqueo	La extracción se sostuvo 92 días sin interrupción
Los registros del portal no estaban integrados al SOC ni existían reglas de enumeración o de herramientas automatizadas	La detección tardó 103 días; una regla sobre los agentes de usuario de herramientas habría alertado el 1 de octubre
Hay credenciales de prueba activas y compartidas en producción	Superficie adicional y ruido que dificulta separar la actividad legítima
El registro no incluye identidad, decisión de autorización, zona horaria ni tamaño de respuesta, y su retención no cubre el inicio del ataque	Impide demostrar el impacto con el registro y fechar con precisión el inicio

7.3 Factores contribuyentes

A las deficiencias técnicas se suman factores de proceso: no hay pruebas de autorización por objeto en el ciclo de desarrollo, no existe un inventario de cuentas de servicio y de prueba, y el servicio atiende cuatro países sin aislamiento por sitio. El análisis de riesgo del activo no consideraba la exposición de datos personales de varias jurisdicciones a través de un mismo endpoint. El origen de las cuatro credenciales usadas por el atacante no está determinado; las hipótesis que se investigan con el proveedor de identidad son cuentas creadas por el propio atacante, credenciales filtradas por viajar en la URL o cuentas de clientes comprometidas.

8. Identificación, contención, erradicación y recuperación

Las acciones se ejecutaron en el orden que mejor equilibra la reducción del riesgo con el efecto sobre los clientes. Primero se aplicaron las medidas reversibles y de efecto inmediato, que detienen la extracción sin afectar a usuarios legítimos. Después se cortó la infraestructura y se revocaron las credenciales del atacante, con aprobación del líder del incidente porque una dirección IP puede estar compartida y la revocación afecta a los titulares de esas cuentas. La corrección del servicio es la única acción que elimina la causa raíz; sin ella, cualquier otra cuenta válida puede repetir el ataque. La rotación general de credenciales se programó después de la corrección porque afecta a todos los clientes.

Fase	Acción	Riesgo que mitiga	Responsable	Estado
Identificación	Preservación del registro original, cadena de custodia y análisis de los tres meses de tráfico	Pérdida o impugnación de la evidencia	Respuesta a incidentes	Ejecutada
Identificación	Caracterización de campañas, cronología, técnicas e indicadores; consulta a fuentes de inteligencia	Respuesta sin alcance claro	Respuesta a incidentes	Ejecutada
Identificación	Solicitud de la relación factura-titular, del esquema de numeración por sitio, de los registros de la aplicación y del proveedor de identidad	Notificar sin confirmar; subestimar o sobrestimar el impacto	Dueño del servicio	En curso
Contención	Límite de peticiones para las cinco IP de la campaña 1 en el endpoint	Continuidad de la extracción	Respuesta a incidentes	Ejecutada

Fase	Acción	Riesgo que mitiga	Responsable	Estado
Contención	Regla del WAF en modo de bloqueo para Scrapy, crawler4j y wget en el endpoint	Extracción automatizada con las mismas herramientas desde otras IP	Respuesta a incidentes	Ejecutada
Contención	Bloqueo de las cinco IP de la campaña 1	Reincidencia desde la misma infraestructura	Respuesta a incidentes	Ejecutada
Contención	Revocación de las cuatro credenciales de la campaña 1	Reutilización de las credenciales desde otras direcciones	Respuesta a incidentes con Identidad	Ejecutada
Contención	Monitoreo reforzado: alerta por más de 50 facturas distintas por credencial y día o por credencial usada desde más de tres IP	Nuevas campañas o reincidencia con otras cuentas	SOC	Ejecutada
Contención	Validación de la campaña 2 con AppSec y QA	Bloquear actividad legítima	AppSec y QA	En curso
Erradicación	Corrección del servicio: validar en cada consulta que la factura pertenece al titular de la sesión y al sitio autorizado	Explotación con cualquier otra cuenta válida	Desarrollo	En curso
Erradicación	Rotación de todas las credenciales del servicio, con el token en cabecera, de vida corta y ligado a la sesión	Uso de credenciales expuestas en registros y proxies	Desarrollo y Arquitectura	En curso, después de la corrección
Erradicación	Retiro de las credenciales de prueba de producción	Uso indebido de cuentas de prueba	QA	En curso
Recuperación	Verificación de la corrección con pruebas de autorización y reproducción del ataque en ambiente de pruebas	Reapertura de la vulnerabilidad	AppSec	Pendiente del despliegue
Recuperación	Monitoreo reforzado durante 30 días y cierre con evidencia de que no se sirven facturas ajenas	Persistencia no detectada	SOC	En curso
Recuperación	Evaluación jurídica y, si se confirma el impacto, notificación a autoridades y titulares	Incumplimiento regulatorio; notificar a quien no fue afectado	Jurídica y Privacidad	En curso

La contención se apoyó en la evidencia disponible y no esperó a la confirmación del impacto, porque las medidas son reversibles y proporcionales al riesgo de seguir exponiendo facturas. La notificación a terceros sí depende de la confirmación, porque afirmar ante una autoridad o un cliente un acceso indebido que no ocurrió tiene consecuencias que no se pueden revertir. Los tiempos de respuesta del caso fueron de 39 minutos desde la detección hasta el plan aprobado (TTR) y de 1 hora 54 minutos hasta la contención aplicada (TTC). Como referencia, un proceso manual sobre el mismo volumen de datos se estima en 24 y 36 horas respectivamente, principalmente por el análisis forense de 4,5 millones de registros. **Estado actual del riesgo: medio.** El atacante identificado está contenido, pero la vulnerabilidad sigue presente hasta el despliegue de la corrección y se mitiga temporalmente con el bloqueo de herramientas automatizadas y el monitoreo reforzado.

EJERCICIO TÉCNICO · INFO

9. Lecciones aprendidas

9.1 Aspectos positivos

- La evidencia se preservó con integridad verificable desde su recepción, lo que permite sostener las conclusiones ante el área jurídica o una autoridad.
- El análisis completo de 4,5 millones de registros y el plan de respuesta estuvieron listos en menos de una hora, y la contención se aplicó en menos de dos.
- Separar la campaña 2 de la campaña 1 evitó una acción de alto impacto sobre lo que parece ser actividad interna.
- Reglas de detección sencillas, probadas contra el histórico, habrían alertado el primer día del ataque y ya están desplegadas.

9.2 Oportunidades de mejora y brechas identificadas

Área	Brecha identificada	Lección
Desarrollo seguro	Ausencia de control de autorización por objeto y de pruebas de autorización en el ciclo de desarrollo	Una credencial válida no debe bastar para acceder a cualquier objeto; la propiedad se valida en cada consulta
Detección y monitoreo	Registros del portal fuera del SOC, sin reglas de enumeración ni de automatización; WAF en modo de detección	Las señales fueron evidentes desde el primer día y la alerta llegó 103 días después

Área	Brecha identificada	Lección
Gestión de credenciales	Credenciales en la URL, de larga duración y utilizables desde cualquier origen; credenciales de prueba en producción	Las credenciales deben tener vida corta, viajar fuera de la URL y estar ligadas a la sesión
Registro y evidencia	Registro sin identidad ni decisión de autorización, con formato no estándar y retención insuficiente	Lo que no se registra no se puede demostrar; el impacto exacto hoy depende de otra fuente
Gestión del riesgo	El análisis de riesgo del activo puede no reflejar la exposición de datos de cuatro jurisdicciones por un mismo servicio	Los controles deben partir del conocimiento del proceso de negocio y de los datos que maneja

10. Recomendaciones

Corto plazo (0 a 30 días)

- Desplegar la corrección del servicio con pruebas de regresión de autorización y verificar en el ambiente de pruebas que el ataque ya no es reproducible.
- Mantener en modo de bloqueo las reglas del WAF para ataques automatizados y extenderlas a límites de peticiones y de objetos por credencial.
- Integrar los registros del portal al SOC para tener una visión completa de las transacciones, y desplegar reglas para detectar intentos masivos de enumeración y actividad automatizada de reconocimiento.
- Completar la corroboración con la relación factura-titular, el esquema de numeración por sitio y los registros de la aplicación y del proveedor de identidad, y profundizar la investigación con actividades forenses complementarias para confirmar el impacto y el origen de las credenciales.

Mediano plazo (1 a 6 meses)

- Evaluar si la misma condición existe en otros portales o aplicaciones con arquitectura similar, en especial los que reciben identificadores de objetos en la petición.
- Priorizar una prueba de Red Team sobre el portal afectado una vez desplegada la corrección.
- Implementar capacidades de inteligencia de amenazas y de threat hunting sobre las plataformas críticas, y fortalecer el monitoreo de fuentes externas donde se divulguen credenciales o información de clientes.
- Completar la rotación de credenciales del servicio y retirar de forma definitiva las credenciales de prueba de los ambientes productivos.

Largo plazo (6 a 12 meses)

- Fortalecer las prácticas de desarrollo seguro mediante Security Champions en cada equipo, un Secure SDLC con pruebas de autorización automatizadas potenciadas por inteligencia Artificial y un proceso de remediación continua.
- Actualizar el análisis de riesgo de ciberseguridad del activo afectado y fortalecer el entendimiento de los servicios y procesos de negocio para implementar controles alineados al contexto operativo.
- Adoptar un estándar de registro con fecha en formato ISO 8601 y zona horaria, usuario, decisión de autorización y tamaño de respuesta, con retención mínima de doce meses.

Glosario

Término	Significado en este reporte
Campaña	Conjunto de direcciones IP y credenciales que actúan de forma coordinada. Se identifica agrupando las IP que usan las mismas credenciales
Credencial (authtoken)	Token que el portal entrega a un cliente y que se envía en cada consulta para identificarlo
Respuesta exitosa (2xx)	Respuesta del servidor que indica que la consulta se atendió y se devolvió la información
IDOR / BOLA	Falla en la que el servicio entrega un objeto (una factura) a partir de su identificador sin verificar que quien lo pide tenga derecho a verlo
Línea base	Comportamiento del tráfico legítimo del servicio, usado como referencia para identificar consultas atípicas
Indicador de compromiso (IoC)	Dato observable que permite identificar la actividad del atacante: direcciones IP, credenciales, herramientas o patrones de petición
Agente de usuario (user agent)	Identificación del programa que realiza la petición, por ejemplo un navegador o una herramienta automática

EJERCICIO TÉCNICO · INFORMACIÓN FICTICIA

Término	Significado en este reporte
Referer	Cabecera que indica la página desde la que se originó una petición
WAF / SOC / SIEM	Firewall de aplicaciones web; centro de operaciones de seguridad; plataforma de correlación de eventos de seguridad
TTD / TTR / TTC	Tiempo hasta detectar el incidente; tiempo desde la detección hasta tener el plan de respuesta; tiempo desde la detección hasta contenerlo
Hecho / evidencia / hipótesis	Dato verificable en el registro / patrón que soporta una inferencia / interpretación que requiere otra fuente para confirmarse

Clasificación TLP:RED. No se debe compartir información designada como **TLP:RED** con ningún tercero fuera del ámbito donde fue expuesta originalmente.

EJERCICIO TÉCNICO · INFORMACIÓN FICTICIA